

THREATMAPPER

Vulnerability Assessment & Penetration Test Report

Date Generated: May 02, 2026 - 17:47:11

Target Scope: Multiple Internal/External Assets

Classification: CONFIDENTIAL

Generated Automatically by ThreatMapper Security Engine

1. Executive Summary

This document outlines the findings of a comprehensive vulnerability assessment performed by ThreatMapper. The objective was to identify security misconfigurations, unpatched vulnerabilities, and structural weaknesses that could be exploited by malicious actors.

A total of 12 vulnerabilities were discovered across the in-scope assets.

Overall System Risk: CRITICAL	Calculated Severity Score: 330
-------------------------------	--------------------------------

Vulnerability Breakdown:

- Critical: 5
- High: 4
- Medium: 3
- Low: 0
- Info: 0

2. Findings Overview Matrix

Target Host	Vulnerability	Severity	CVSS	OWASP Class
api.target-company.c	Path Traversal	High	7.5	A01:2021 Broken Access Control
dev.target-company.c	BOLA (Broken Object Level Authoriza	High	8.5	API1:2023 Broken Object Level Autho
admin.target-company	Race Condition	High	7	A04:2021 Insecure Design
admin.target-company	SSRF Detected	High	8.6	A10:2021 Server-Side Request Forger
api.target-company.c	XSS Reflected	Medium	6.1	A03:2021 Injection
api.target-company.c	CSRF Vulnerability	Medium	6.5	A01:2021 Broken Access Control
dev.target-company.c	Open SSH Port	Medium	6.5	A05:2021 Security Misconfiguration
api.target-company.c	SQL Injection Possible	Critical	9.8	A03:2021 Injection
dev.target-company.c	Default Credentials Detected	Critical	9.1	A07:2021 Identification and Authent
dev.target-company.c	JWT Misconfiguration	Critical	9	A02:2021 Cryptographic Failures
admin.target-company	SSTI (Template Injection)	Critical	9.8	A03:2021 Injection
admin.target-company	Command Injection	Critical	9.8	A03:2021 Injection

3. Detailed Vulnerability Analysis

1. SQL Injection Possible [Critical]

Affected Host: api.target-company.com

CVSS Base Score: 9.8

OWASP Category: A03:2021 Injection

Technical Details / Proof of Concept:

Database error on /api/users?id= parameter (MySQL 5.7).

Recommended Remediation:

Refactor database queries to use Parameterized Queries (Prepared Statements) or an Object Relational Mapper (ORM).

2. Default Credentials Detected [Critical]

Affected Host: dev.target-company.com

CVSS Base Score: 9.1

OWASP Category: A07:2021 Identification and Authentication Failures

Technical Details / Proof of Concept:

dev/dev credentials accepted via SSH.

Recommended Remediation:

Immediately change all default vendor credentials. Implement strong password policies and MFA.

3. JWT Misconfiguration [Critical]

Affected Host: dev.target-company.com

CVSS Base Score: 9

OWASP Category: A02:2021 Cryptographic Failures

Technical Details / Proof of Concept:

API accepts tokens with alg=None or weak secret "secret".

Recommended Remediation:

Use strong HMAC secrets or RSA keys. Strictly enforce the algorithm header (reject "none") and validate token expiration.

4. SSTI (Template Injection) [Critical]

Affected Host: admin.target-company.com

CVSS Base Score: 9.8

OWASP Category: A03:2021 Injection

Technical Details / Proof of Concept:

Template engine evaluated {{7*7}} -> 49.

Recommended Remediation:

Follow standard secure coding practices. Refer to OWASP guidelines for mitigation techniques specific to this class of vulnerability.

5. Command Injection [Critical]

Affected Host: admin.target-company.com
CVSS Base Score: 9.8
OWASP Category: A03:2021 Injection

RCE via Jenkins script console automation endpoint.

Recommended Remediation:

Avoid passing user input to system shells. Use language-specific safe API methods (e.g. subprocess without shell).

6. Path Traversal [High]

Affected Host: api.target-company.com
CVSS Base Score: 7.5
OWASP Category: A01:2021 Broken Access Control

Arbitrary file read via ?file=../../etc/passwd

Recommended Remediation:

Avoid direct file inclusion via user input. Whitelist allowed paths or sanitize input strictly using realpath checks.

7. BOLA (Broken Object Level Authorization) [High]

Affected Host: dev.target-company.com
CVSS Base Score: 8.5
OWASP Category: API1:2023 Broken Object Level Authorization

Can access other users profiles by changing /api/user/12 -> 13

Recommended Remediation:

Implement explicit server-side authorization checks on every data access request ensuring the user owns the specific object ID.

8. Race Condition [High]

Affected Host: admin.target-company.com

CVSS Base Score: 7

OWASP Category: A04:2021 Insecure Design

Technical Details / Proof of Concept:

Double spend possible by sending simultaneous requests to /checkout.

Recommended Remediation:

Implement database row locking (e.g., SELECT ... FOR UPDATE) or mutexes around critical transaction code.

9. SSRF Detected [High]

Affected Host: admin.target-company.com

CVSS Base Score: 8.6

OWASP Category: A10:2021 Server-Side Request Forgery

Technical Details / Proof of Concept:

Internal services accessed via webhook URL parameter.

Recommended Remediation:

Implement an explicit whitelist of allowed domains/IPs for backend requests. Deny all private IP range resolution.

10. XSS Reflected [Medium]

Affected Host: api.target-company.com

CVSS Base Score: 6.1

OWASP Category: A03:2021 Injection

Technical Details / Proof of Concept:

Input field vulnerable to parameter reflection: <script>alert(1)</script>

Recommended Remediation:

Ensure strict contextual output encoding. Use a modern web framework that auto-escapes HTML characters.

11. CSRF Vulnerability [Medium]

Affected Host: api.target-company.com

CVSS Base Score: 6.5

OWASP Category: A01:2021 Broken Access Control

Technical Details / Proof of Concept:

No anti-CSRF tokens present on state-changing POST requests.

Recommended Remediation:

Implement synchronized anti-CSRF tokens for all state-changing POST/PUT/DELETE requests.

12. Open SSH Port [Medium]

Affected Host: dev.target-company.com

CVSS Base Score: 6.5

OWASP Category: A05:2021 Security Misconfiguration

Technical Details / Proof of Concept:

Port 22 exposed to external network. Brute force feasible.

Recommended Remediation:

Ensure SSH uses Key-Based authentication and disable Root login. Change default port if applicable.